



# STRIDE Threat Modeling

Analisis Keamanan Sistem untuk Proyek: Hotel Booking Secure System

LAPORAN PENILAIAN RISIKO KEAMANAN & MITIGASI



# Metodologi STRIDE

STRIDE adalah kerangka kerja yang dikembangkan oleh Microsoft untuk membantu mengidentifikasi potensi ancaman terhadap sistem komputer.

Spoofing

Tampering

Repudiation

Info Disclosure

Denial of Service

Elevation of Privilege





# Identifikasi Ancaman (T-01 – T-05)

| ID   | STRIDE                                                                                        | ANCAMAN                      | KOMPONEN     | RISK     | MITIGASI                 |
|------|-----------------------------------------------------------------------------------------------|------------------------------|--------------|----------|--------------------------|
| T-01 |  SPOOFING    | Kredensial hasil brute force | Login System | HIGH     | Rate limiting + logout   |
| T-02 |  SPOOFING    | Credential stuffing          | Login System | HIGH     | MFA + deteksi login      |
| T-03 |  SPOOFING  | Phishing login page palsu    | User         | HIGH     | HTTPS + edukasi user     |
| T-04 |  SPOOFING  | Session hijacking (XSS)      | Session      | HIGH     | HttpOnly + Secure cookie |
| T-05 |  TAMPERING | SQL Injection form login     | Backend      | CRITICAL | Prepared statement       |



# Identifikasi Ancaman (T-06 – T-10)

| ID   | STRIDE                                                                                          | ANCAMAN                      | KOMPONEN    | RISK     | MITIGASI               |
|------|-------------------------------------------------------------------------------------------------|------------------------------|-------------|----------|------------------------|
| T-06 |  TAMPERING     | Manipulasi parameter booking | Booking Sys | HIGH     | Validasi server-side   |
| T-07 |  TAMPERING     | Perubahan nominal bayar      | Payment     | CRITICAL | Integrity check        |
| T-08 |  TAMPERING   | Parameter tampering API      | API         | HIGH     | Input sanitization     |
| T-09 |  TAMPERING   | Manipulasi callback payment  | Payment GW  | CRITICAL | Signature verification |
| T-10 |  REPUDIATION | User menyangkal transaksi    | Payment     | MEDIUM   | Logging + timestamp    |



# Identifikasi Ancaman (T-11 – T-15)

| ID   | STRIDE                                                                                              | ANCAMAN                  | KOMPONEN    | RISK     | MITIGASI              |
|------|-----------------------------------------------------------------------------------------------------|--------------------------|-------------|----------|-----------------------|
| T-11 |  REPUDIATION       | Admin menyangkal data    | Admin Panel | MEDIUM   | Audit trail           |
| T-12 |  INFO DISCLOSURE   | Password plaintext       | Database    | CRITICAL | bcrypt hashing        |
| T-13 |  INFO DISCLOSURE | Kebocoran via MitM       | Session     | HIGH     | HTTPS enforcement     |
| T-14 |  INFO DISCLOSURE | Kebocoran file .env      | Server      | CRITICAL | Env config protection |
| T-15 |  INFO DISCLOSURE | Data sensitif di URL/Log | Server      | MEDIUM   | Masking policy        |



# Identifikasi Ancaman (T-16 – T-20)

| ID   | STRIDE                                                                                                     | ANCAMAN                 | KOMPONEN    | RISK     | MITIGASI           |
|------|------------------------------------------------------------------------------------------------------------|-------------------------|-------------|----------|--------------------|
| T-16 |  DENIAL OF SERVICE        | Flood login request     | Server      | HIGH     | Rate limiting      |
| T-17 |  DENIAL OF SERVICE        | Spam booking request    | Backend     | MEDIUM   | Throttling         |
| T-18 |  ELEVATION OF PRIVILEGE | Bypass RBAC fitur admin | Admin Panel | HIGH     | RBAC enforcement   |
| T-19 |  ELEVATION OF PRIVILEGE | Session var overloading | Session     | CRITICAL | Session validation |
| T-20 |  ELEVATION OF PRIVILEGE | Bypass reset token      | Backend     | CRITICAL | Secure token gen   |



# Identifikasi Ancaman (T-21 – T-23)

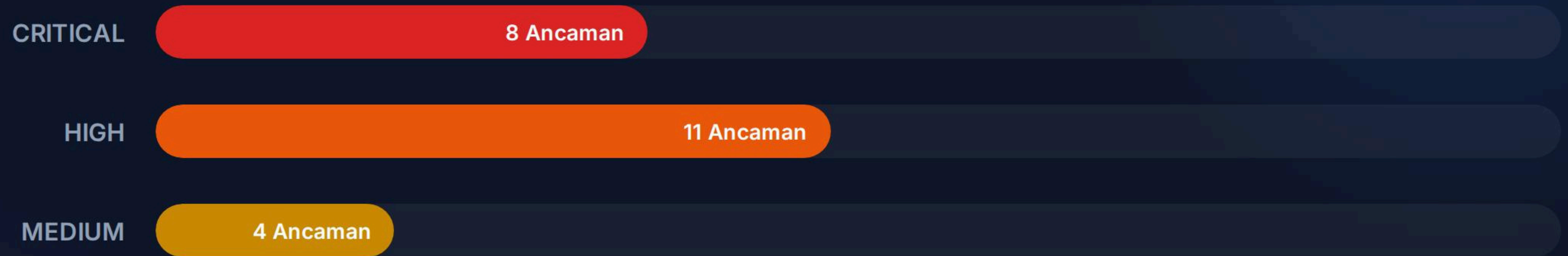
| ID   | STRIDE                                                                                              | ANCAMAN                | KOMPONEN | RISK     | MITIGASI            |
|------|-----------------------------------------------------------------------------------------------------|------------------------|----------|----------|---------------------|
| T-21 |  TAMPERING         | Replay attack callback | Payment  | HIGH     | Timestamp & Nonce   |
| T-22 |  SPOOFING          | Fake callback PG       | Payment  | CRITICAL | IP Whitelist + Sign |
| T-23 |  INFO DISCLOSURE | API key di source code | Server   | CRITICAL | Env variables       |

## Analisis Data Selesai

Total 23 ancaman telah diidentifikasi dan diklasifikasikan berdasarkan kategori STRIDE dengan rencana mitigasi yang sesuai.



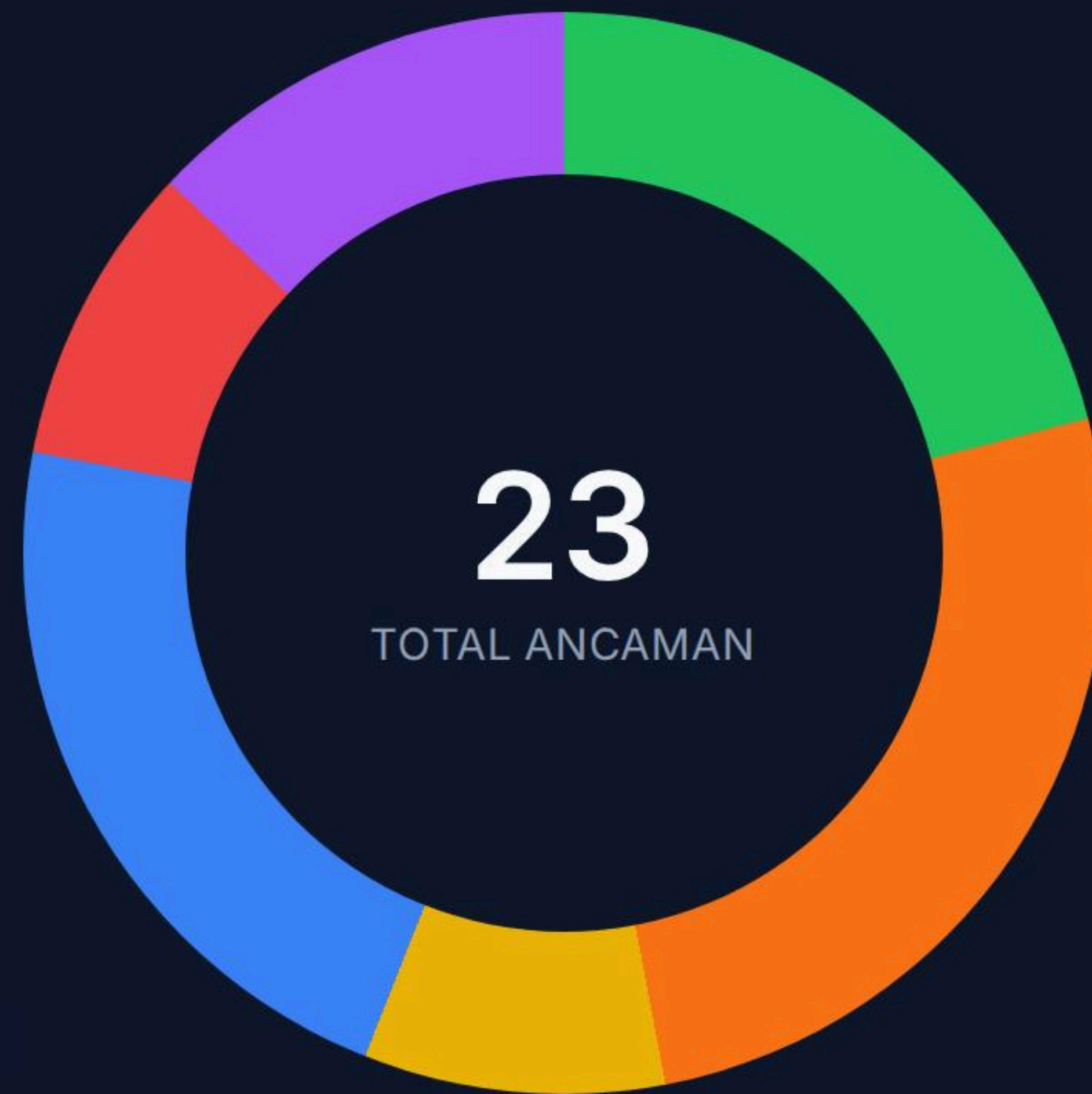
# | Distribusi Level Risiko



*"Mayoritas ancaman berada pada level **HIGH** (48%) dan **CRITICAL** (35%), menunjukkan perlunya implementasi keamanan prioritas tinggi pada sistem booking dan pembayaran."*



# | Komposisi Kategori STRIDE



- Tampering (6)
- Spoofing (5)
- Information Disclosure (5)
- Elevation of Privilege (3)
- Repudiation (2)
- Denial of Service (2)